CO1-AT3-ASSIGNMENT

1) Ambiguous Scope and Unlisted Vulnerable Systems

- **Strict Adherence to Scope & Written Authorization:-**
A one line authorization email is legally hazardous. Penetration testing requires an explicit contract. Without the system explicitly enumerated in writing, testing or exploiting it breaches stated computer fraud statutes
- **Principles of least Harm**: Exploitation carries an inherent risk of service distribution, data corruption or triggering unintend-ed cascading failures, especially on an asset whose function and criticality are unknown.
- **Duty to disclose**: Ethical hackers have a fiduciary and ethical obligation to inform the client immediately rather than leveraging an unvetted entry point.

CORRECT ACTION:

Cease testing on that target, document the discovery and contact the clients authorized technical liaison to report the critical exposure and formalize the scope.

2) Live customer data & SQL injection

Stop data dumps: Immediately halt automated or table-wide exfiltration tools (sqlmap --dump, UNION extracts)

Benign PoC Only: Prove execution with harmless meta data or non-destructive time delays (Select @@version, pg_sleep(3))

Report & Redact: Alert the client immediately about exposed PII / finance data, mask sensitive records in logs / screenshots and encrypt notes.

Pre-engagement precautions:

- Mandate testing on isolated staging / UAT environment with sanitized synthetic data.
- Define contractual handling rules for PII/PEI data and set hard exploitation ceilings in the rules of engagement.

3) Accidential Denial-of-Service

Immediate Response:

Kill the tooling: Abort all scans, scripts and threads instantly.

Call Emergency POC: Directly telephone the 24/7 technical lead - do not rely on email.

Triage & assist: Provide source IP, timestamp, target and the offending payload; help infrastructure teams unblock resources or restart services

Root-cause Memo: Document why the root cause occured and revise test parameters

Prevention:

(i) Cap request rates and thread counts (--rate-limit, -T3 or lower)

(ii) Ban high-concurrency fuzzing and heavy, unindexed queries on production assets.

(iii) Restrict invasive tests to monitored, off peak maintenance windows

4) Covert Testing without IT knowledge

Risks

↳ Wasted incident response : IT/Blue teams mistake the test for a real attack, burning critical emergency resources or pulling systems offline.

↳ Legal/ISP Blowback : Unaware defenders may report your IPs to law enforcement, hosting providers, or ISPs, causing black listing or account bans.

↳ Fog of War : A real threat actor striking simultaneously would be masked or misattributed to your activity.

Protective Safegaurds :

Executive authorization : Secured a signed "Get out of Jail Free" letter from C-level leadership (CEO, CISO)

Trusted Agent (white cell) : Assign one senior stakeholder aware of the test monitor activity and confirm identity during escalations.

Static source IPs : Test exclusively from dedicated pre-declared IPs so logs can immediately distinguish your activity from real attackers.

Instant Abort protocol : Establish emergency code words and direct phone contacts to halt the engagement immediately if needed.

5) Red Team Exercise vs Vulnerability Assessment : Bank scenario

ASPECT	VULNERABILITY (VA)	RED TEAM EXERCISE
Goal	Find and catalog as many flaws as possible (breadth)	Reach a specific target like a real attacker (depth)
Approach	automated scans, audits and checklists.	phishing, chained exploits and lateral movements.
Physical Scope	Inspect locks, test badge readers and review CCTV with staff	Tailgate through doors, clone employee badges and plant rogue devices
Digital Scope	Automated port/patch scans across all public IPs and banking APPs	Spear-phish staff, evade end point detection and pivot toward core banking / SWIFT Networks
Rules & Awarness	IT/SOC are informed and assist during pre-set maintenance windows	IT/SOC are unaware; Overseen only by a small trusted executive "white cell" with strict no-go limits.